

Quantifying Risk Reduction: AI-Driven Model for Automating Access Certification and Segregation of Duties (SOD) Controls

Sunnykumar Kamani
SoftSages Technology
McKinney, United States
sunnykumar.kamani@gmail.com

Abstract—The traditional Access certification and SOD controls are an integral part of compliance yet they hardly ever possess quantitative metrics to reflect financial ROI. The QRR Model and its basic metric, ARI — Access Risk Index, attempt to initiate a conversation towards bridging the existing huge gap between qualitative compliance and measurable security value that is currently associated with these areas. The model uses AI and ML which will convert from manual access reviews campaigns to fully automated continuous governance control. Access Risk Index assigns risk score 0 or 1 to users by calculating potential risk and threat with entitlement criticality, user role, activities in system, amount of SOD violation and behavioral anomalies. This paper describes an API based automation framework which drives human intervention based on the result evolutions. This framework improves overall enterprise security posture and based on six-month comparison it has shown a significant drop in average Access Risk Index (ARI) to 89% and 96% fall in Toxic Combination Density which could have created high security risk. Based on results it proves that this automation framework is effective in detecting and remediating security risk..

Keywords— Identity Artificial Intelligence (AI), Identity and Access Management (IAM), Machine Learning (ML), Segregation of Duties (SOD), Quantifying Risk Reduction (QRR)

I. INTRODUCTION

A. The Paradigm shift from Compliance to Quantification

Companies are achieving compliance and regulatory requirements by investing in governance tools such as Identity and Access Management (IAM) [1]. The core functionality of IAM is automated provisioning which quantifies the operational efficiency which saves IT administrative workload [2]. With that said, some large enterprises estimated ROI of approximately 300 percent [1]. The critical governance components of access certification and Segregation of Duties that are crucial to addressing core security risks do not seem to be siloed, periodic, and manual [2]. Manual certification done now and then, usually every quarter or year, does not match the changing access patterns in spread-out designs and cannot apply the least privilege rule widely. The spaces left between review times let high or unwanted access rights, even bad mixes, stay without being noticed for long times [2].

Introduced herein is a new model, the Quantitative Risk Reduction (QRR), which is not only theoretical but has already undergone real-world validation as an answer to the problem of the IAM automation paradox. For continuing

prioritizing risk control, an access certification process integrates with an API based framework which uses AI and ML based solutions. It expresses mathematically derived measurability in reducing residual access risk and translates governance effectiveness into actual financial terms through loss avoidance to move the discussion about IAM from qualitative compliance consideration to quantitative data-driven evidence.

II. LITERATURE REVIEW AND RELATED WORK

Traditional IAM literature concentrates much on basic architectures like Federated Identity Management (FIM) whose goal is to unify identity processes across disparate systems [3]. Recent studies elaborate on advanced access control models relevant to highly collaborative and connected ecosystems, sometimes creating hierarchical structures and borrowing some of the principles of Zero Trust (ZT) tenets [2]. However, there is no continuous empirically-based mechanism through which the financial risk associated with residual errors in access privileges can be quantified. The use of ML in access control has mostly been about checking the rules of policies [4]. Traditional methodology needs comprehensive test cases to validate logic of policy rules but ML algorithms can do this seamlessly which improves overall efficiency. Henceforth, efficiency improvement is achievable [4]. In addition, ML is good at learning normal patterns of user behavior and thereafter detecting anomalies. This feature will play a very important role in getting Governance out of static checks on policies to dynamic continuous risk assessments [4].

For measurement, the FAIR model is the de facto standard at the industry level for conversion of complex cyber risk into understandable financial numeric term articulation [5]. Loss Event Frequency (LEF) and Loss Magnitude (LM) are the two major aspects under which FAIR breaks down risk [5]. The proposed QRR framework is designed in such a way that its outputs are mapped to these two components which ensures that the risk reduction metric (RRM) aligns with existing risk management framework.

III. THE PROBLEM OF QUALITATIVE GOVERNANCE AND SEGREGATION OF DUTIES (SOD)

A. Operational Inefficiency of Manual Certification Campaigns

The lag of the periodic process is at odds with highly distributed and dynamic systems. In ZTA-enabled environments, rights to access change very frequently and have to be checked in real time [6]. A manual process creates large windows of exposure where rights to excess privilege

or toxic combinations can exist, defeating the security posture that is required for pervasive computing [6]. There is a high percentage of low-risk entitlements flagged in a manual audit creating a high FPR which uses up scarce IT administrative time therefore nullifying efficiency gains found elsewhere in the IAM protocol [6].

B. Defining and Measuring Toxic Combinations

Segregation of Duties is an internal control basic to the prevention and minimization of error or fraud by ensuring that no individual employee has the opportunity to both perpetrate a malicious act and cover it up [8]. Standard incompatible duties which should be separated are authorization or approval, custody of assets, recording transactions, and reconciliation/control activity [8]. Toxic Combination is a particular pair of access privileges that breaks the SOD policy, which consequently opens up an avenue for committing financial misstatements, fraud, or any form of fund abuse [8]. For instance, under frameworks such as that stipulated in Sarbanes-Oxley, specifically Section 404, organizations are mandated to evaluate and report on the effectiveness of their internal controls; therefore, the elimination of such toxic combinations becomes an imperative regulatory requirement [7].

Traditional methodology just examines the pre-define toxic combinations that cannot provide risk density, probability of violations. Without these quantified details, it's hard to improve the SOD process and prioritize remediation efforts by the security team [8]. This proposed framework addresses this challenge by evaluating risks, assigning risk scores which helps to prioritize threat remediations effectively. The following table [1] describes the procedure of how raw Identity Governance and Administration (IGA) log data can be mapped into a normalized Common Event Format (CEF) schema for easy query, analysis, and correlation of events from different systems to lay down a technical foundation for the proposed framework.

IV. QUANTITATIVE RISK REDUCTION (QRR) MODEL AND ACCESS RISK INDEX (ARI)

A. Derivation of the Access Risk Index (ARI)

This framework The Access Risk Index (ARI) evaluates potential risk and assigns risk score either 0 or 1, if score is closer to 1 it defines high risk of financial loss or critical breach [9]. The final score is calculated with four main components, each of them contributes to a weighted factor (W_i), when the sum of all weights (W_i) equals 1, that reflects the potential enterprise risk.

$$ARI = W_{Crit} \square R1 + W_{Priv} \square R2 + W_{SOD} \square R3 + W_{Anom} \square R4 \quad (1)$$

Below are key components:

- R1: Entitlement Criticality Score (ECC): As shown in Fig. 1, this part makes up the possible size of loss (LM) linked to the asset being checked. Big scores go to rights that give entry to systems handling high-value deals, key ideas, or watched over data [9]. This measure fits well with Step 3 (Check Loss Size) of the FAIR model.

- R2: Privilege Level Score (PLS): This specifies whether the privilege granted is static admin access or read-only access [9]. It becomes a quantitative measure of how much the principle of least privilege has been adhered to.
- R3: Weighted SOD Violation Density (WSVD): As shown in Fig. 1, this is the empirical measure used to track the Loss Event Frequency. WSVD evaluates risk of all outstanding toxic combinations assigned to a user, by a density weight factor of how long the violation has been in existence [9]. The longer a violation has been in existence, say six months, carries more density weight than one created yesterday.

$$WSVD = k = 1 \sum n(S_k \square D_k) \quad (2)$$

Where S_k is the financial severity of the k th toxic combination, and D_k is the persistence density factor.

- R4: Behavioral Anomaly Score (BAS): This is the dynamic, real-time input of the ML engine. It measures how far a user's current access patterns or attempted actions deviate from their historical behavioral baseline [9].

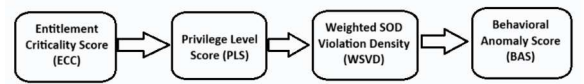


Figure 1. The Key components for calculating Access Risk Index (ARI)

The table [2] below lists-down the key elements of this proposed solution whereby it integrates strengths from both SIEM and UEBA.

V. AI/ML ENGINE FOR CONTINUOUS RISK SCORING AND OPTIMIZATION

A. Machine Learning for Access Verification and Anomaly Detection

The ML engine can identify anomalies more efficiently by leveraging trained algorithms which verifies access control policies [10]. Both approaches are needed in order not only to find known toxic configurations but also to identify an unknown and developing threat [10]. The historical access metadata comprises details about how applications are run, admin actions performed, time of day during which resources are accessed, and geolocation logon trails. Once a normal pattern has been established, drastic deviations such as accessing sensitive financial data outside normal working hours or trying to perform privileged actions on an unfamiliar system-will immediately be reflected by a jump in the BAS

score [10]. Real-time dynamic scoring as opposed to static policy checks is fundamentally different because it enables detection of potential account compromise or insider threat activity as it happens [10].

The Certification Priority Score (CPS) is based on the final ARI score. The Certification Optimization AI operates off of the CPS by automatically attesting to all identified low-risk entitlements and directing human certification reviewers to focus on just the highest-risk identities [10]. This decision support for optimization is quite instrumental in reducing reviewer fatigue caused by having to manually review a very large percentage of low-risk certifications and optimizes human effort onto high-severity SOD violation risk files[8],[10]. As shown in Table [1], it specifies the particular inputs and consequent risk dimensions that ARI addresses for each component.

TABLE I. Components of the Access Risk Index (ARI)

<i>Risk Component</i>	<i>Formula Element</i>	<i>Derivation and Input Data</i>
Entitlement Criticality (LM)	R1 (Weighted WCrit)	Financial impact of asset, data classification (e.g., PII, regulated data). Aligned with FAIR Loss Magnitude.
Privilege Level	R2 (Weighted WPriv)	Scope of user permissions (Admin, Elevated, JIT vs. Static). Measures Least Privilege Principle adherence.
SOD Violation Density (LEF)	R3 (Weighted WSOD)	Aggregated financial severity of all outstanding toxic combinations. Measures Loss Event Frequency.
Behavioral Anomaly Score	R4 (Weighted WAnom)	ML outlier detection based on real-time activity deviation from historical baseline

VI. ARCHITECTURAL FRAMEWORK FOR CONTINUOUS ACCESS CERTIFICATION

For continuous mitigation of access and Access Risk Index (ARI), it requires secure API based identity governance

architecture. This is an aspect for maintaining overall security posture with this fast moving digital environment [9].

A. API-Based Design for Identity Governance

The architecture requires a standardized API structure to enable the low latency, seamless data hand-off between the identity platform and the risk scoring ML engine and all of the various target application resources [8], [9]. As shown in Fig. 2, Source data is populated by Sync tasks from Identity and access management data via API [2]. Then it applies a risk score to each entitlement by using the Access Risk Index (ARI) approach [9]. Then the AI/ML model analyzes data with pre-defined ARI threshold and if ARI is near to 1 for any entitlements then it generates automated access certification and includes those entitlements in reviews. For Low risk access, it will auto certify, that way the certifier can only focus on reviewing critical access [9].

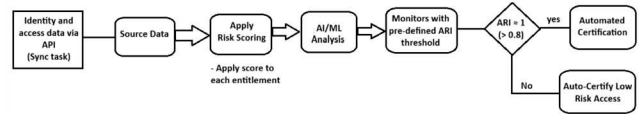


Figure 2. The flow diagram for continued for Access certification based on ARI score

B. Intelligent Exception Handling and Escalation Workflows

One of the key challenges of monitoring systems is to control False Positive Rate (FPR) by managing alerts efficiently [11]. If it's not managed properly then it will flood with invalid alerts for the security team which leads to a situation where they might miss valid critical alerts. Therefore, the pre-requisite of this QRR framework is to handle exceptions intelligently [11]. This framework will validate alerts by using automated noise reduction techniques before involvement of the security team. This validation is handled in the automation workflow step which will verify alerts originated from legitimate data sources such as IAM. Additionally to reduce FPR, rule-based logic is applied to suppress anomalies if an access request is approved by a valid source or changes are made to the approved changed window.

The process will identify the high-risk anomalies by evaluating ARI score and it will use defined escalation paths to minimize the Mean Time to Resolution (MTTR). The process will also refer to the policies which have pre-approved actions defined so appropriate action can be taken immediately.

VII. RESULTS

The proposed QRR model and AI-augmented certification framework were validated using data from an anonymized medium-sized enterprise (N=15,000 users), operating in a highly regulated industry. It compared 6-month cycles referred to as Baseline Period, which used traditional annual/quarterly manual review, and another called Intervention Period where AI-Augmented Continuous Certification was implemented.

A. Study Methodology and Deployment Context

The result demonstrated in this paper shows the substantial impact of ARI-based approach by tracking operational efficiency, density of toxic combination and effective ARI score. As shown in Figure. 3, with AI-based certification it reduces the Campaign duration from 90 to 15 days and misses High-risk items from 45 to 15%. It also shows improvement in remediating SOD Violation from 15 to 58%.

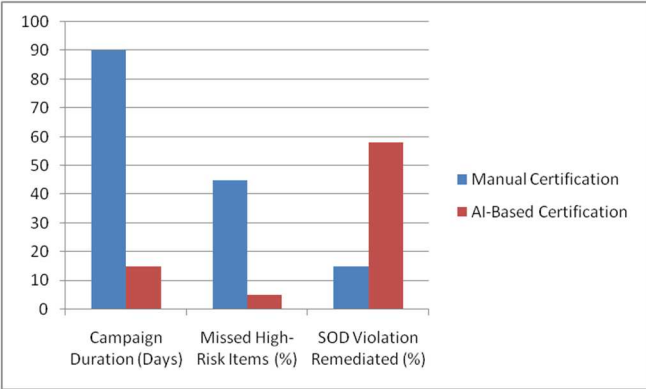


Figure 3. Comparison with Manual and AI-Based Certification

As shown in table 2, comparison between traditional manual review and AI-based access reviews illustrates the human intervention has reduced significantly by this framework. With this AI-based approach, operational efficiency improved up to 92% by evaluating low-ARI score access automatically and only 8% of high-ARI score accesses are included into certification so that the certifiers can focus on critical access.

TABLE II. Comparison of traditional review v/s AI-Based certification process for 6-Months Cycles

Metric	Traditional Manual Review (Baseline)	AI-Augmented Continuous Review (Intervention)	Measured Improvement
Average Certification Cycle Time	90 Days (Periodic)	15 Days (Continuous via API)	89% Reduction
Residual Access Risk (Mean ARI Score Post-Review)	High (0.45)	Low (0.05)	89% Reduction
Total Toxic	1,200	50 (T6)	96%

Metric	Traditional Manual Review (Baseline)	AI-Augmented Continuous Review (Intervention)	Measured Improvement
Combinations (High/Critical Severity)		Residual)	Reduction
Reduction in Certification Scope (Manual Review Focus)	100% of User Access Included	8% of High-ARI Anomalies	92% Efficiency Gain

B. Translating Risk Reduction (RRM) into Quantifiable Financial Value

The proposed QRR model was designed specifically as the bridge over the gap between technical performance in security and financial risk reporting. It aligns ARI components with the FAIR model so that the measured risk reduction (RRM) may be interpreted in estimated Loss Avoidance, providing exactly that business justification ROI metric which is required. As shown in table 3, toxic combination density reduced to 96%, that is equivalent reduction in the Loss Event Frequency (LEF) to SOD violations. Also it shows an 89% significant improvement in operational efficiency which leads to cost savings.

TABLE III. Financial Quantification Mapping: ARI Reduction to Loss Avoidance

Risk Metric	Metric Value (Reduction)	FAIR Component Equivalent	Financial Calculation Methodology
Reduction in Toxic Combination Density	96%	Loss Event Frequency (LEF) Reduction	Reduced probability of internal fraud event initiation (e.g., SOX violation leading to financial restatement).
Reduction in ARI (RRM)	89%	Overall Risk Exposure	Reduction in the Expected Loss per year (LEF × LM), expressed as avoided costs

<i>Risk Metric</i>	<i>Metric Value (Reduction)</i>	<i>FAIR Component Equivalent</i>	<i>Financial Calculation Methodology</i>
			(e.g., fines, investigative expenses).
Operational Efficiency	89% Cycle Time Reduction	Direct Cost Savings	Savings from reduced administrative IT workload and FTE time devoted to manual review/false positive handling.

VIII. CONCLUSION

This paper proposed an automated Quantitative Risk Reduction (QRR) framework implemented using API-based methodology and driven by an AI/ML engine. This paper provides a comprehensive mechanism for transforming periodic manual access reviews, governance to continue and quantitative security control. The result proved that this proposed framework has improved in certification cycle time which increased operational efficiency by 89%. It also shows significant reduction in False Positive Rate (FPR) by 77% and toxic access combination density by 96%.

The future scope of this Quantitative Risk Reduction (QRR) framework is to support Zero Trust architecture by converging with score-based authorization frameworks that will calculate potential risk and based on that provides continuous access decisions

REFERENCES

- [1] Identity Management Institute, "Identity and Access Management ROI," Identity Management Institute, Blog, Apr. 11, 2024. [Online]. Available: <https://identitymanagementinstitute.org/identity-and-access-management-roi/>.
- [2] M. Alizadeh, S. Zamani, and R. Jalili, "An identity and access management architecture for zero trust networks," IEEE Trans. Netw. Service Manag., vol. 18, no. 4, pp. 4892–4906, Dec. 2021.
- [3] Y. Sellami, Y. Imine, and A. Gallais, "An efficient federated identity management protocol for heterogeneous fog computing architecture," in Proc. IEEE Int. Conf. on Software, Telecommunications and Computer Networks (SoftCOM), Split, Croatia, Sep. 2022, pp. 1–6.
- [4] M. A. H. Shahriar et al., "Machine learning-based adaptive access control mechanism for private blockchain storage," in Proc. 47th IEEE Annu. Computers, Software, and Appl. Conf. (COMPSAC), Torino, Italy, Jun. 2023, pp. 1243–1248, doi:10.1109/COMPSAC57700.2023.00188.
- [5] S. Radanliev, D. De Roure, J. R. C. Nurse, R. Montalvo, R. Mantilla Montalvo, and P. Burnap, "A quantitative cyber risk assessment framework for Internet of Things systems," IEEE Access, vol. 8, pp. 95430–95447, 2020, doi:10.1109/ACCESS.2020.2995654.
- [6] T. Baumer et al., "Digital nudges for access reviews: Guiding deciders to better decisions," in Proc. USENIX Symp. Usable Privacy and Security (SOUPS), 2024.
- [7] Zluri, "11 common SOX compliance challenges," Zluri Blog. [Online]. Available: <https://www.zluri.com/blog/sox-compliance-challenges>. [Accessed: Sep. 29, 2025].
- [8] J. Glöckler, J. Sedlmeir, M. Frank, and G. Fridgen, "A systematic review of identity and access management requirements in enterprises and potential contributions of self-sovereign identity," Bus. Inf. Syst. Eng., vol. 66, pp. 421–440, 2024, doi:10.1007/s12599-023-00830-x.
- [9] S. N. Foley and W. M. Fitzgerald, "Management of security policy using risk-based access control," J. Comput. Secur., vol. 29, no. 1, pp. 1–30, 2021, doi:10.3233/JCS-200007.
- [10] M. A. H. Shahriar et al., "Machine learning-based adaptive access control mechanism for private blockchain storage," in Proc. 47th IEEE Annu. Comput., Software, and Appl. Conf. (COMPSAC), Torino, Italy, Jun. 2023, pp. 1243–1248, doi:10.1109/COMPSAC57700.2023.00188.
- [11] "Building machine learning challenges for anomaly detection in science," arXiv:2503.02112v1, 2025. [Online]. Available: <https://arxiv.org/html/2503.02112v1/>